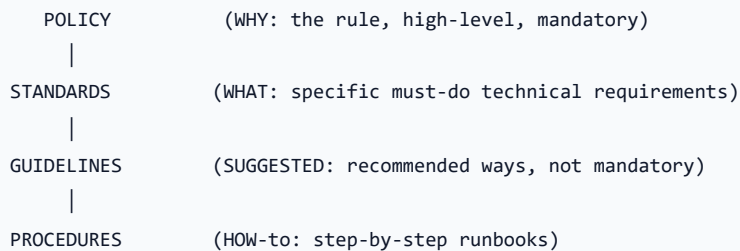


Security Policies, Standards & Guidelines

The Governance Pyramid



Policy = "you must." Standard = "this exact version/way." Guideline = "best attempt." Procedure = "in this order."

Common Policies You Must Know

Acceptable Use Policy (AUP) – what employees may do with company IT
Data Classification & Handling – public / internal / confidential / restricted

Password & Access Policy – who, what strength, MFA requirement

Bring Your Own Device (BYOD) policy

Remote Access / VPN policy

Incident Response policy – the authority that IR jumps when activated

Business Continuity / Disaster Recovery

Privacy policy (GDPR/CCPA dimension, module 17)

A Policy Is Useless Alone

A policy works when it's:

Written for a reader (clear, short, enforceable)

Owned + reviewed (annual review, named owner)

Tied to reality (else it's aspirational paper)

Enforced & measured (controls enforce; metrics check)

Policy vs Standard Example

POLICY: "All production systems must support strong authentication."

STANDARD: "MFA is mandatory on all external logins."

GUIDELINE: "Prefer FIDO2 over OTP where the platform supports it."

PROCEDURE: "1. Create MFA enrollment → 2. Attach device → 3. Test recovery."

The governance insight: documents don't secure anything – but they make 'who is accountable' and 'what is the rule' knowable, and that's the precondition for every technical control.

[← Module start](#)

[Security Law: CFAA, GDPR, HIPA...](#)